

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

CIS Controles de Seguridad Crítica v8.1

**** Aplicación práctica, medición, evidencia y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, asesores y equipos de seguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Silencio **Inside:** 18 Controles • 153 Salvaguardias • IG1, IG2, IG3 • medición • evidencia • herramientas • manual de gestión • laboratorios • preparación de la carrera Silencio...

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Este manual educativo independiente no es un Centro para la publicación, certificación, acreditación, informe de auditoría, opinión legal o garantía de seguridad o cumplimiento. Controles CIS y CIS Los parámetros son marcas comerciales del Centro de Seguridad de Internet. Utilice los recursos oficiales CIS para el contenido exacto y la orientación actual.

Los controles CIS son las mejores prácticas de ciberseguridad. No reemplazan las leyes, reglamentos, contratos, requisitos sectoriales, evaluación de riesgos o responsabilidad de gestión aplicables. Un mapeo muestra relaciones; no prueba automáticamente el cumplimiento de otro marco.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en activos, redes, aplicaciones, cuentas de nube, repositorios y datos que posee o está específicamente autorizado por escrito para evaluar. Use información sintética y sistemas aislados en laboratorios.

Prefacio

Una introducción práctica para priorizar la defensa cibernética y la medición basada en evidencia.

Los Controles CIS convierten las necesidades defensivas comunes en salvaguardias focalizadas. Su fuerza es la priorización práctica: saber lo que posee, controlar software y datos, asegurar configuraciones e identidades, gestionar vulnerabilidades y registros, prepararse para perturbaciones y ataques, y probar si las defensas funcionan.

La versión 8.1 es la edición actual. Se trata de una actualización iterativa al v8 que realineó mappings to NIST CSF 2.0, definiciones ampliadas de plazo reserva, clases de activos revisados y cartografías de Salvaguardia, problemas menores corregidos, aclarar algunas Salvaguardias, e incorporar la función de seguridad de Govern en las cartografías. Los 18 Controles y 153 Salvaguardias siguen siendo la estructura central.

Una instalación de herramientas no es la implementación. La aplicación efectiva requiere un alcance definido, poblaciones completas, configuración segura, pruebas operativas, propietarios capacitados, manejo de excepciones, medición, corrección y retesting. Los administradores deciden prioridades y recursos; los analistas hacen que esas decisiones sean fiables mediante inventarios y pruebas precisos.

Cómo utilizar este manual

- Los administradores deben comenzar con los Capítulos 1-5 y 24–25.
- Los analistas juniores deben estudiar los 18 capítulos de Control, método de medición, herramientas, laboratorio y capítulo de entrevista.
- Los equipos técnicos deben conectar cada Salvaguardia a activos, datos, propietarios, procedimientos, configuración, monitoreo, manejo de excepciones y pruebas.
- Los evaluadores deben utilizar la Evaluación oficial de Controles CIS Especificación de insumos, operaciones, medidas, métricas, suposiciones y exámenes de procedimiento.

Contenido de la palabra:** Este documento contiene un campo de mesa de contenido de Word nativo. La guía del capítulo contendrá números de página verificados para esta edición. Después de editar, haga clic con el botón derecho en el contenido y elija el campo de actualización, luego actualice la tabla completa. Silencio.

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

Tabla de contenidos [4](#table-of-contents)

1. CIS Controls v8.1 Foundations [7](#cis-controls-v8.1-foundations)

2. Grupos de aplicación y prioridades [8](#implementation-groups-and-prioritization)

3. Gobernanza, alcance y propiedad [9](#governance-scope-and-ownership)

4. Medición con la Evaluación de CIS Especificación [10](#measurement-with-the-cis-assessment-specification)

5. Implementation Roadmap [11](#implementation-roadmap)

6. Control 1 - Inventario y Control de Activos Empresarios [12](#control-1-inventory-and-control-of-enterprise-assets)

7. Control 2 — Inventario y control de activos de software [13](#control-2-inventory-and-control-of-software-assets)

8. Control 3 — Data Protection [14](#control-3-data-protection)

9. Control 4 — Configuración segura de activos y software de la empresa [16](#control-4-secure-configuration-of-enterprise-assets-and-software)

10. Control 5 — Account Management [18](#control-5-account-management)

11. Control 6 — Access Control Management [19](#control-6-access-control-management)

12. Control 7 - Gestión continua de la vulnerabilidad [21](#control-7-continuous-vulnerability-management)

13. Control 8 — Audit Log Management [23](#control-8-audit-log-management)

14. Control 9 — Email and Web Browser Protections [24](#control-9-email-and-web-browser-protections)

15. Control 10 — Malware Defenses [25](#control-10-malware-defenses)

16. Control 11 — Data Recovery [26](#control-11-data-recovery)

17. Control 12 — Network Infrastructure Management [27](#control-12-network-infrastructure-management)

18. Control 13 — Network Monitoring and Defense [28](#control-13-network-monitoring-and-defense)

19. Control 14 — Security Awareness and Skills Training [30](#control-14-security-awareness-and-skills-training)

20. Control 15 — Service Provider Management [31](#control-15-service-provider-management)

21. Control 16 — Application Software Security [32](#control-16-application-software-security)

22. Control 17 — Gestión de la respuesta de incidentes [34] (#control-17-incident-response-management)

23. Control 18 — Penetration Testing [36](#control-18-penetration-testing)

24. Open-Source Tools [37](#open-source-tools)

24.1 CIS Controls Navigator [37](#cis-controls-navigator)

24.2 CIS Controls Assessment Specification [37](#cis-controls-assessment-specification)

24.3 CIS-CAT Lite [37](#cis-cat-lite)

24.4 CISO Assistant [38](#ciso-assistant)

24.5 Wazuh [38](#wazuh)

24.6 osquery [38](#osquery)

24.7 OpenSCAP [38](#openscap)

24.8 Lynis [38](#lynis)

24.9 Nmap [39](#nmap)

24.10 Greenbone Community Edition [39](#greenbone-community-edition)

24.11 Trivy [39](#trivy)

24.12 OWASP ZAP [39](#owasp-zap)

24.13 Suricata [39](#suricata)

24.14 Keycloak [39](#keycloak)

24.15 DefectDojo [40](#defectdojo)

24.16 Velociraptor [40](#velociraptor)

25. El CIS Controls Playbook [41](#managers-cis-controls-playbook)

26. Guía de la carrera de analista junior [42](#junior-analyst-career-guide)

26.1 Trabajo junior típico [42](#typical-junior-work)

27. Laboratorio de Ficción y Cartera [44](#fictional-laboratory-and-portfolio)

28. Plan de aprendizaje de 30 días [45] (#thirty-day-learning-plan)

29. Preparación de entrevistas [46](#interview-preparation)

29.1 ¿Cuáles son los controles CIS? [46](#what-are-the-cis-controls)

29.2 ¿Qué es IG1? [46](#what-is-ig1)

29.3 ¿Se ajusta IG1 a cada requisito? [46](#does-ig1-fit-every-requirement)

29.4 ¿Cómo mide una Salvaguardia? [46](#how-do-you-measure-a-safeguard)

29.5 ¿Por qué son importantes los inventarios? [46](#why-are-inventories-important)

29.6 Vulnerability scan versus penetración test? [46](#vulnerability-scan-versus-penetration-test)

29.7 ¿Una asignación marco demuestra el cumplimiento? [46](#does-a-framework-mapping-prove-compliance)

29.8 ¿Qué puede concluir un analista junior? [46](#what-can-a-junior-analyst-conclude)

29.9 Preguntas para hacer al empleador [46](#questions-to-ask-the-employer)

30. Plantillas, Glosario, Índice y Referencias [48](#templates-glossary-index-and-references)

30.1 Documentos de trabajo de medición de seguridad [48](#safeguard-measurement-workpaper)

30.2 Registro de búsqueda y prueba [48](#finding-and-retest-record)

30.3 Glosario [48](#glossary)

30.4 Índice de asunto [49](#subject-index)

30.5 Referencias oficiales [49](#official-references)

1. Controles CIS v8.1 Fundaciones

La versión actual, estructura, propósito y limitaciones.

“El control organiza 153 Salvaguardias en un programa defensivo práctico” (Nota: 3.94164in”
alt=“Los controles organizan 153 Salvaguardias en un programa defensivo práctico.” /

Figura 1. Los 18 controles de seguridad críticos CIS

- CIS Controls v8.1 fue publicado en junio de 2024 y sigue siendo la edición actual a partir de julio de 2026.
- Los Controles se priorizan las mejores prácticas diseñadas para defender sistemas y redes contra ataques frecuentes.
- El marco contiene 18 Controles y 153 Salvaguardias.
- Las salvaguardias se refieren a las clases de activos, las funciones de seguridad y los grupos de aplicación.
- La versión 8.1 alinea su cartografía NIST CSF a CSF 2.0 e incluye cartografías Govern.
- Existen mapas oficiales para múltiples marcos, pero la aplicación debe verificarse por separado para cada requisito aplicable.

Silencio **Layer** Silencio... Silencio Control Silencio Resultado defensivo amplio, como inventario de activos o respuesta a incidentes — Salvaguardia Silencio Acción focalizada que puede ser

asignada, implementada y medida Silencio Clase de activos Silencio Tipo de tema afectado, tales como dispositivos, software, datos, red, usuarios o documentación Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía Silencio Grupo de Aplicación Silencio Priorización recomendada basada en el perfil de riesgo y los recursos Medida de evaluación de la vida útil Entradas, operaciones, medidas, métricas y revisión de procedimientos utilizados para evaluar una salvaguardia sometida

2. Grupos de aplicación y prioridades

Cómo IG1, IG2, y las organizaciones de ayuda IG3 eligen un punto de partida realista.

■img src="media/image2.png" estilo="Ancho:6.15in; Altura:3.39605in" alt="Cada grupo se construye sobre el grupo anterior; IG3 contiene todas las Salvaguardias." /

Gráfico 2 Progresión del Grupo de Aplicación

Silencio **La situación física** Silencioso** Silencio

————— Silencio IG1 Silencio 56 Silencio Recursos de seguridad limitados y experiencia; menor sensibilidad; alta necesidad de continuidad básica Silencio Esencial de la higiene cibernética contra ataques comunes Silencio IG2 Silencio IG1 + 74 Silencio Múltiples departamentos, mayor complejidad, información sensible y dependencia más operativa Silencio Gestionar mayor riesgo y complejidad operacional Silencio IG3 Silencio IG1 + IG2 + 23 = 153 Silencio Especialistas en seguridad, datos confidenciales o regulados, servicios críticos y amenazas sofisticadas Silencio Reducir el impacto de ataque apuntado y avanzado

- Cada empresa debe comenzar con IG1 según la orientación CIS.
- Seleccione un IG considerando la sensibilidad de los datos, los servicios críticos, la exposición a amenazas, las obligaciones jurídicas y contractuales, la tolerancia empresarial, la tecnología, la dotación de personal y los conocimientos especializados.
- Un IG es una ayuda de priorización, no permiso para ignorar un riesgo material o requisito obligatorio.
- Adiciones, secuencias, excepciones, aceptación de riesgos, propietarios y fechas.
- Utilice el navegador oficial de control CIS para filtrar v8.1 Salvaguardias y mapas de revisión.

3. Gobernanza, alcance y propiedad

La base de gestión necesaria para que las Salvaguardias funcionen de forma sistemática.

- Definir los objetivos institucionales, los servicios críticos, los datos confidenciales, las obligaciones jurídicas y contractuales, el perfil de amenazas, la tolerancia al riesgo y el Grupo de Aplicación elegido.

- Crear inventarios completos para activos empresariales, software, datos, cuentas, sistemas de autenticación, infraestructura de red, registros, proveedores, aplicaciones y recursos de recuperación.
- Assign one accountable owner for each Safeguard and operational owners for each affected platform or process.
- Definir el alcance, la aplicabilidad, las dependencias, las responsabilidades del proveedor de servicios, las excepciones permitidas, la autoridad de aprobación y los desencadenantes de revisión.
- Planificar financiación, personas, habilidades, tecnología, tiempo y gestión del cambio.
- Definir las métricas y la presentación de informes antes de la aplicación para que la cobertura y el fracaso sean visibles.
- Operar un ciclo de gobernanza: priorizar, implementar, medir, corregir, retestar y mejorar.

Silencio **Role** Silencio **Decisión o responsabilidad** Silencio... – Patrocinador ejecutivo
 Silencioso Dirección, tolerancia al riesgo, financiación, escalada y rendición de cuentas
 Silencioso Propietario de control Silencio Diseño de salvaguardias, alcance, procedimiento, medición, excepciones y mejora Silencio Asset o propietario de servicio Silencio Inventario exacto, uso aprobado, configuración, impacto de negocios y remediación TENAS Operaciones de seguridad TENIDO Monitoreo, alerta, investigación, respuesta y evidencia TEN IT / Engineering TENIDO Implementación, control de cambio, parche, configuración y recuperación TEN GRC / Analyst ANTE Mapping, evidencia, medición, hallazgos, seguimiento de la acción y reportaje TENIDO tención Auditoría interna / evaluador tención Servicio prestado Silencio Controles, pruebas, incidentes, cambios y soporte de salida

4. Medición con la especificación de evaluación CIS

Un método repetible para decidir si se aplican salvaguardias.

)

Inicio rápido seguro: Elija v8.1, seleccione un grupo de implementación y mapeo, revise salvaguardias, luego exporte la selección autorizada.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.2 CIS Controls Assessment Specification

Objetivo: Orientación oficial de medición. Proyecto oficial: [Seguido] [Según datos](#)

Inicio rápido seguro: Abra una Salvaguardia, identifique los insumos y las suposiciones, siga las operaciones, calcule las medidas y revise el procedimiento de documentos.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.3 CIS-CAT Lite

Propósito: CIS seleccionado Evaluación de parámetros. Proyecto oficial: [Seguido] (<https://learn.cisecurity.org/cis-cat-lite>)

Inicio rápido seguro: Ejecutar sólo en sistemas autorizados, elegir un punto de referencia y perfil disponibles, preservar el informe, validar las conclusiones, corregir y reevaluar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.4 CISO Assistant

Propósito: Controles, riesgos, pruebas y hallazgos. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un proyecto de alcance, cargar un marco aplicable, asignar propietarios, adjuntar evidencia, resultados de seguimiento y permisos de revisión.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.5 Wazuh

Propósito: Monitoreo de punto final, SIEM, FIM y alertas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un punto final de laboratorio, desencadenar un evento seguro, confirmar la recogida y alerta, investigar, y retener la cobertura y la evidencia de respuesta.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.6 osquery

Propósito: Consultas de activos, software, cuenta y configuración. Proyecto oficial: (<https://www.osquery.io/>)

Comienzo rápido seguro: Ejecute consultas sólo de lectura en un laboratorio, programe consultas aprobadas, compare resultados a inventarios, y plataforma de documentos y límites de cobertura.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.7 OpenSCAP

Objetivo: Evaluación de la configuración segura de Linux. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Elija un perfil apropiado, escanear un sistema de laboratorio, validar resultados, excepciones de documentos, remediar y cambiar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.8 Lynis

Propósito: Auditoría de seguridad de Linux. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: auditar un host de laboratorio, revisar los hallazgos contra el alcance y las normas, asignar acciones, corregir elementos seleccionados y repetir.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.9 Nmap

Propósito: Activo autorizado y descubrimiento de servicios. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un escaneo limitado en rangos escritos, comparar con inventario, investigar servicios desconocidos, y retener el alcance y la evidencia de comando.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.10 Greenbone Community Edition

Objetivo: Evaluación de la vulnerabilidad. Proyecto oficial: [ejecutado]Greenbone Community Edition (10)(<https://greenbone.github.io/docs/latest/>)

Inicio rápido seguro: Actualizar los alimentos, utilizar los objetivos autorizados y las credenciales, validar la cobertura de activos, revisar las conclusiones, remediar y cambiar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.11 Trivy

Propósito: Repositorios, imágenes, dependencias, secretos e IaC. Proyecto oficial: [ejecutado]Trivy seleccionado/u fiel](<https://trivy.dev/>)

Inicio rápido seguro: Escanear un repositorio de prueba o imagen, validar hallazgos, documentar excepciones justificadas, fijar y rescán en el oleoducto.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.12 OWASP ZAP

Propósito: Pruebas de seguridad web autorizadas. Proyecto oficial: [Seguido] (<https://www.zaproxy.org/>)

Comenzar rápido seguro: Proxy una aplicación de entrenamiento, arrastrar pasivamente, utilizar el escaneo activo sólo con aprobación, validar hallazgos, correcto y retest.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.13 Suricata

Propósito: detección de intrusión en red y visibilidad del tráfico. Proyecto oficial: [Seguido] (<https://suricata.io/>)

Inicio rápido seguro: Use un sensor de laboratorio, confirme la interfaz y las reglas, genere tráfico de prueba aprobado, valide alertas, sintonice cuidadosamente, y preserve la historia del cambio.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.14 Keycloak

Propósito: Identidad, roles, MFA, sesiones y eventos. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un reino de laboratorio, roles y MFA, probar casos de compás, revisar eventos y configuración de documentos y resultados.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.15 DefectoDojo

Propósito: Encontrar ingesta, deduplicación, remediación y retest. Proyecto oficial: [Seguido](#)

Comienzo rápido seguro: Importar resultados seguros, validar la deduplicación, asignar propietarios y fechas, adjuntar prueba, y cerrar sólo después de la prueba verificada.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.16 Velociraptor

Finalidad: visibilidad y respuesta a incidentes. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Despliegue sólo en un laboratorio autorizado aislado, recoja un artefacto estrecho, alcance de documentos y acceso, investigue los resultados y retire los datos del laboratorio con seguridad.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

25. Manual de Controles CIS de Manager

Las preguntas, el tablero, la propiedad y los administradores de decisiones deben controlar.

1. ¿El IG elegido sigue siendo apropiado para datos sensibles, servicios críticos, exposición a amenazas, obligaciones, escala y habilidades?
2. ¿Están las poblaciones centrales completas, actuales, de propiedad y reconciliadas con el descubrimiento independiente?
3. ¿Qué Salvaguardias IG1 tienen cobertura incompleta, revisión atrasada, datos de entrada no fiables o excepciones de repetición?
4. ¿Se han intensificado los accesos administrativos, los sistemas expuestos externamente, los programas informáticos no respaldados, las vulnerabilidades críticas y los fallos de recuperación?
5. ¿Las alertas resultan en investigación y respuesta, o sólo en el volumen de panel?
6. ¿Se entienden las responsabilidades de los proveedores de servicios, las pruebas, las obligaciones de incidentes, los subcontratistas y los planes de salida?
7. ¿Se autorizan pruebas de penetración y ejercicios de forma segura, con un alcance adecuado, realizados independientemente cuando sea necesario y seguidos a través de la prueba?
8. ¿Qué financiación, personal, tiempo de ingeniería o decisión empresarial está bloqueando la corrección?

Area Silencio ** Cuestión del personal Silencio**————— **Silencio IG y alcance Silencio** ¿Se documentan las prioridades, adiciones, exclusiones y obligaciones? Verde /

Amarillo / Rojo – Inventories Silencio ¿Están completos los activos, software, datos, cuentas, proveedores, aplicaciones y registros? Verde / Amarillo / Rojo TEN Protection TEN ¿Operan la configuración, el acceso, el parche, el correo electrónico, el malware y los controles de datos? Verde / Amarillo / Rojo Silencio Detección Silencio ¿Se ha completado la cobertura de registro y red y se han revisado las alertas? Verde / Amarillo / Rojo – Recuperación Silencio ¿Están protegidos copias de seguridad y restauraciones probadas contra las necesidades de negocio? Verde / Amarillo / Rojo Silencio Respuesta Silencio ¿Son los roles, contactos, umbrales, ejercicios y revisiones actuales? Verde / Amarillo / Rojo TENED ¿Se corrigieron las poblaciones confiables y de excepción? Verde / Amarillo / Rojo ¿Son compatibles las pruebas, limitaciones, hallazgos y pruebas? Verde / Amarillo / Rojo

26. Junior Analyst Career Guide

Una ruta práctica en controles, vulnerabilidad, seguridad, GRC y operaciones de seguridad funcionan.

■img src="media/image10.png" style="width:6.15in;height:2.9948lin" alt="Aprende el marco, mapa Salvaguardias, mide evidencia, reporte lagunas, y construya un portafolio honesto".

Gráfico 10 Junior CIS Controles vía analista

Controles de Seguridad Junior Analista

GRC Analista

Analista de Gestión de Vulnerabilidad

Análisis de la seguridad

Análisis de las operaciones de seguridad

Analista de Cumplimiento de TI

Third-Party Risk Analyst

Cybersecurity Program Analyst

26.1 Típico trabajo junior

- Mantener inventarios de activos, software, datos, cuentas, sistemas de red, proveedores, aplicaciones, hallazgos y pruebas.
- Reunir pruebas sin cambiar los registros de fuentes y validar la integridad de la población.
- Mapa Salvaguardias a propietarios, sistemas, procedimientos, configuración, evidencia, métricas, excepciones y acciones.
- Ejecute las herramientas autorizadas de descubrimiento, configuración, vulnerabilidad, registro o seguridad de aplicaciones bajo procedimientos aprobados.

- Calcular la cobertura y las métricas de excepción utilizando la estructura de evaluación oficial.
- Seguimiento de software no compatible, activos no autorizados, problemas de acceso, vulnerabilidades, copias de seguridad fallidas, lagunas de alerta y hallazgos de proveedores a través de la prueba.
- Escribir conclusiones claras sin reclamar autoridad o certeza más allá de las pruebas.

Silencioso** Silencio... TENIDO Marco TENIDO Explicar los 18 Controles, IGs, clases de activos y funciones TENIDO Silencio Inventario Silencio Reconcile dos fuentes independientes y explicar las diferencias TENEDO TENIDO Mostrar insumos, operaciones, medidas, métrica, lista de excepciones y conclusión TENIDO – Alfabetización técnica Silencio Interpret configuración, identidad, escaneo, registro, recuperación y evidencia de aplicación TEN Remediation Silencio Trace finding to owner, due date, correction, and verified retest TEN TEN Comunicación ANTERIGEN Escribe un resumen del administrador de una página y un documento de trabajo detallado – Ética – Utilizar datos sintéticos, autorización, límites de alcance y afirmaciones honestas

27. Laboratorio Ficcional y Portfolio

Un entorno de prácticas seguras utilizando datos sintéticos y sistemas de laboratorio autorizados.

- La regla del laboratorio* Utilizar organizaciones ficticias, datos sintéticos, sistemas aislados y autorización escrita. Nunca ataque objetivos públicos, utilice credenciales reales o publique la producción de herramientas sensibles. Silencio.
1. Crear una compañía ficticia de 50 personas con laptops, servidores, servicios en la nube, una aplicación web, personal remoto y cinco proveedores.
 2. Seleccione IG1 y documente tres adiciones basadas en el riesgo de IG2 o IG3.
 3. Construir inventarios de activos, software, datos, cuenta, sistema de autenticación, red, proveedor, aplicación y fuente de registro.
 4. Use Nmap y osquery en un laboratorio aislado para conciliar los inventarios de activos y software.
 5. Utiliza OpenSCAP o Lynis en un host de laboratorio; conclusiones de configuración de documentos, excepciones, correcciones y reevaluación.
 6. Use Greenbone en los objetivos de laboratorio aprobados; valide la cobertura, los hallazgos, la remediación y la reutilización.
 7. Use Wazuh o Suricata para generar e investigar una alerta de prueba segura.
 8. Use Trivy o ZAP en un repositorio de entrenamiento o aplicación y registre y repita.
 9. Escriba un registro de prueba de copia de seguridad y una tabla de incidentes.

10. Crear cinco documentos de trabajo de evaluación de CIS con insumos, operaciones, medidas, métricas, listas de excepciones y conclusiones.
11. Publicar sólo artefactos sanitarios y afirmar claramente que el proyecto es ficticio y no una evaluación formal CIS.

Silencio **Artifact** Silencio **Lo que prueba** Silencio Silencio... TEN IG selection memo TEN Prioritization and risk reasoning TEN – Reconciliación de los inventarios Silencioso papel de salvaguardia Silencio Estructura de medición oficial y pruebas Reevaluación de la configuración TENIDO Búsqueda técnica, corrección y retestigo TEN Vulnerability report – Cobertura, priorización, excepción y remediación Silencioso Caso de detección Silencio Restaurar prueba Silencioso Disponibilidad y pruebas de recuperación tención Administrador dashboard Silencio Clear risk and action communication

28. Plan de aprendizaje de 30 días

Un calendario centrado para la capacidad útil de nivel inferior.

Días Silencio** Silencio————— TENIDO 1–4 TENIDO Marco, 18 Controles, 153 Salvaguardias, IGs, clases de activos, funciones TENIDO Marco concepto mapa y IG memo ANTE tención 5–8 Silencioso Activos, software, datos, cuentas, acceso Silencio Cuatro inventarios reconciliados TEN 9–12 TENIDO Configuración, vulnerabilidad, email, malware TEN Lab configuración y papel de trabajo de vulnerabilidad Silencio 13–16 Silenciosos Logs, monitoreo, defensa de la red Silencio Mapa fuente de registro y seguro caso de alerta Silencio 17–19 Silencioso recuperación y respuesta a incidentes Silencio Restaurar prueba y registro de mesa Silencio 20–22 Silencio Proveedores y seguridad de aplicaciones Silencio Evaluación del Proveedor y lista de verificación para el desarrollo seguro Silencioso 23–25 Evaluación de la vida Especificación Silencio Cinco medidas de seguridad completas Silencio 26–28 Silencio Laboratorios autorizados de herramientas y remediación TEN 29–30 TENIDO Portfolio y entrevistas TENIDO Portafolio Sanitizado y cinco historias de STAR TEN

29. Preparación de entrevistas
 - Respuestas claras, escenarios prácticos y preguntas para el empleador.*

29.1 ¿Cuáles son los Controles CIS?

Un conjunto priorizado de mejores prácticas defensivas organizadas en 18 Controles y 153 Salvaguardias enfocadas.

29.2 ¿Qué es IG1?

El punto de partida esencial de la higiene cibernética 56-Safeguard que CIS recomienda que cada empresa comience.

29.3 ¿Importa IG1 cada requisito?

Es una base de referencia de priorización. El riesgo material, los contratos, las leyes, los clientes o los servicios críticos pueden requerir salvaguardias adicionales.

29.4 ¿Cómo mide una Salvaguardia?

Utilizar criterios oficiales, dependencias, hipótesis, aportaciones completas, operaciones definidas, medidas, métricas, revisión de procedimientos, excepciones y pruebas.

29.5 ¿Por qué son importantes los inventarios?

Definen a las poblaciones que deben cubrir los controles de configuración, vulnerabilidad, registro, recuperación y respuesta.

29.6 Vulnerability scan versus penetración test?

Un escaneo identifica principalmente debilidades conocidas; la prueba de penetración utiliza el análisis humano calificado y la explotación controlada para evaluar el impacto y la resiliencia.

29.7 ¿Una cartografía de marco demuestra el cumplimiento?

No. Identifica las relaciones, pero la organización debe probar el requisito y la evidencia exacta aplicable.

29.8 ¿Qué puede concluir un analista junior?

Sólo lo que el alcance definido y el soporte de evidencia confiable, con muestreo y limitaciones claramente reveladas.

29.9 Preguntas para hacer al empleador

¿Qué grupo de implementación y adiciones están en alcance?

¿Cómo se crean y reconcilian las poblaciones de inventarios?

¿Qué Salvaguardias tienen la cobertura más incompleta?

¿Cómo se revisan los datos de medición y las excepciones?

¿Qué herramientas de código abierto y comerciales son aprobadas?

¿Cómo se priorizan, financian y prueban los resultados?

¿Cómo revisará el trabajo de los funcionarios superiores?

30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos importantes y puntos de partida autorizados.*

30.1 Documentos de trabajo de medición de salvaguardia

Silencio** Silencio. “La Salvaguardia de la Vida” y la IG “Antes” “Escopia y clase de activos” “Principal y sistemas de vida” Las dependencias y las suposiciones de la vida Inputs y validación de la vida “Operaciones en la vida” “Las medidas de la vida” “Metric and interpretation

TENIDO” Excepciones y limitaciones de la vida La acción, el dueño, la fecha y la prueba de la vida

30.2 Finding and retest record

Silencio** Silencio... Los Criterios de la vida siguen adelante. “Acondicionamiento y evidencia de vida” La población afectada está en peligro. “El riesgo y el impacto en la vida” TENIDO Cause TENED

“La protección provisional en la vida” Corrección y propietario de la vida La fecha de su muerte es la siguiente. “El procedimiento de la prueba de mentiras” Resultado final de la vida útil

30.3 Glosario

Silencio** Silencio. Silencio Clase Asset Silencio Categoría afectada por una Salvaguardia, como dispositivos, software, datos, red, usuarios o documentación. Silencio Silencio CIS Benchmark – Recomendaciones de configuración segura para una tecnología específica. tención CIS Control Silencio Una de las 18 amplias áreas defensivas. confidencialidad CIS Salvaguardia Silencio Una acción enfocada y implementable dentro de un Control. – TENCIÓN TENIDA Compartir de la población aplicable en la que se implementa adecuadamente la Salvaguardia. Silencio Silencio IG1 tención 56 salvaguardas esenciales de la higiene cibernética. Silencio IG2 Silencio IG1 más 74 Salvaguardias adicionales. TENIDA IG3 TENIDA IG1 e IG2 más 23 Salvaguardias adicionales; todos 153. TENCIÓN TENIDO Una cuenta, lista, fecha, configuración o resultado producido por operaciones de evaluación. Silencio TENIDO TENIDO Cálculo o interpretación construido a partir de medidas. Silencio Población Silencio Completo conjunto de registros, activos, personas, sistemas o eventos aplicables. tención Revisión de procedimiento tención Evaluación manual de si existe un proceso necesario y contiene los elementos necesarios. Silencio Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía.

30.4 Índice de asunto

Subjeto** Silencio... Silenciosos Cuentas Silencio para la seguridad de la aplicación Silencioso inventario de activos Silenciosos registros de auditoría Silencio Protección de datos TENIDO Evidencia y medición TENIDO 4 Silenciosos Grupos de Aplicación Silencio Respuesta del incidente Silencioso analista junior Silencio Silencio Silencio Silencioso Silencioso en la Red 17-18 Silencio Herramientas de código abierto Silencio 24 Silencio pruebas de Penetración Silencioso Silencioso de recuperación proveedores de servicios Silencio 20 Silencio Silencioso Inventario de software TEN TERRITORIO TERRITORIO TERRITORIO TEN TERRITORIO DE Vulnerabilidad ANTE LAS 12

30.5 Referencias oficiales

[](<https://www.cisecurity.org/controls/v8-1> Controles v8.1

Nota de Controles CIS

[](<https://www.cisecurity.org/controls/implementation-groups>)

Seguido

Seguido

Seguido

[]u]CIS Controles cartografías y cumplimiento efectuados/u
título](<https://www.cisecurity.org/cybersecurity-tools/mapping-compliance/mapping-and-compliance-with-the-cis-controls>)

Silencio **Recuerdo final:** Cambio de marcos, mapas, herramientas, productos, amenazas, leyes, contratos y riesgos organizativos. Confirme los recursos oficiales actuales y las obligaciones aplicables antes de una aplicación o evaluación reales. Silencio Respuesta